

บทที่ 4

การทดลองและผลการทดลอง

4.1 บทนำ

ในการทดลองจะเป็นการทดสอบระบบที่ได้สร้างขึ้นโดยแยกการทดสอบออกเป็น 3 การทดสอบคือ

1. ทดสอบระบบป้องกันผู้บุกรุกทางเครือข่าย
2. ทดสอบระบบตรวจจับผู้บุกรุก
3. ทดสอบโปรแกรมต่อต้านการบุกรุกช่องโหว่ทางซอฟต์แวร์
4. ทดสอบระบบการกู้คืนระบบ

4.2 การทดสอบที่ 1 ทดสอบระบบป้องกันผู้บุกรุกทางเครือข่าย

4.2.1 วิธีการทดสอบ

1. ทดลองสแกนพอร์ต server ที่ติดตั้งระบบป้องกันผู้บุกรุกทางเครือข่าย
2. ทดลองบุกรุกทางด้านเครือข่าย
3. ตรวจสอบว่าระบบสามารถป้องกันได้

4.2.2 ผลการทดสอบ

จากการทดสอบพบว่า

- 1) ทดลอง สแกนพอร์ตโดยใช้โปรแกรม nmap

```
C:\Documents and Settings\Mayhem>nmap -PO 161.246.5.32

Starting Nmap 4.20 ( http://insecure.org ) at 2007-01-29 18:54 Dateline Standard
Time
Interesting ports on isag32.ce.kmitl.ac.th (161.246.5.32):
Not shown: 1693 closed ports
PORT      STATE      SERVICE
21/tcp    open      ftp
22/tcp    open      ssh
179/tcp   filtered  bgp
873/tcp   open      rsync
MAC Address: 00:0C:29:14:98:A7 (VMware)

Nmap finished: 1 IP address (1 host up) scanned in 27.735 seconds

C:\Documents and Settings\Mayhem>
```

รูปที่ 4.1 แสดงการสแกนพอร์ตเพื่อหาช่องโหว่

- 2) โดยตัวระบบป้องกันผู้บุกรุกทางเครือข่ายจะรู้ว่ามีการมาทำการ สแกนพอร์ต

ID	Signature	Priority	Timestamp	Ip_source	Ip_destination	Type
1-(1-9782)	BLEEDING-EDGE SCAN NMAP -f-sS	2	2007-01-29 18:54:05	161.246.5.20:45807	161.246.5.32:667	tcp
2-(1-9781)	BLEEDING-EDGE SCAN NMAP -sS	2	2007-01-29 18:54:05	161.246.5.20:45807	161.246.5.32:667	tcp
3-(1-9780)	BLEEDING-EDGE SCAN NMAP -f-sS	2	2007-01-29 18:54:05	161.246.5.20:45811	161.246.5.32:179	tcp
4-(1-9779)	BLEEDING-EDGE SCAN NMAP -sS	2	2007-01-29 18:54:05	161.246.5.20:45811	161.246.5.32:179	tcp
5-(1-9778)	BLEEDING-EDGE SCAN NMAP -f-sS	2	2007-01-29 18:54:04	161.246.5.20:45810	161.246.5.32:6105	tcp
6-(1-9777)	BLEEDING-EDGE SCAN NMAP -sS	2	2007-01-29 18:54:04	161.246.5.20:45810	161.246.5.32:6105	tcp
7-(1-9776)	BLEEDING-EDGE SCAN NMAP -f-sS	2	2007-01-29 18:54:04	161.246.5.20:45810	161.246.5.32:4987	tcp
8-(1-9775)	BLEEDING-EDGE SCAN NMAP -sS	2	2007-01-29 18:54:04	161.246.5.20:45810	161.246.5.32:4987	tcp
9-(1-9774)	BLEEDING-EDGE SCAN NMAP -f-sS	2	2007-01-29 18:54:04	161.246.5.20:45809	161.246.5.32:68	tcp
10-(1-9773)	BLEEDING-EDGE SCAN NMAP -sS	2	2007-01-29 18:54:04	161.246.5.20:45809	161.246.5.32:68	tcp
11-(1-9772)	BLEEDING-EDGE SCAN NMAP -f-sS	2	2007-01-29 18:54:04	161.246.5.20:45808	161.246.5.32:479	tcp
12-(1-9771)	BLEEDING-EDGE SCAN NMAP -sS	2	2007-01-29 18:54:04	161.246.5.20:45808	161.246.5.32:479	tcp

รูปที่ 4.2 ขึ้นเตือนว่ามีการทำสแกนพอร์ต

- 3) ทดลองบุกรุกผ่านทางเครือข่าย โดยช่องโหว่ที่หาได้โดยลงหาช่องโหว่ของโปรแกรม Snort เอง

```
Secure:/home/secure/Snort - Milw0rm/Snort - Milw0rm# ./test1 161.246.5.32 172.16.24.35

-----
| Snort 2.4.0-2.4.2 Back Orifice Preprocessor Remote Exploit |
| by Russell Sanford - xort@tty64.org                       |
-----

[+] Patching Shellcode to Connect back to 172.16.24.35.
[+] Creating Evil Packet.
[+] Using Return Address: 0xbfffebad.
[+] Encrypting Packet.
[+] Preparing to Send Evil UDP Packet to 161.246.5.32.
[+] Sending Packet.
[+] Listening for Connect Back Shellcode.
```

รูปที่ 4.3 กำลังบุกรุกผ่านโปรแกรม Snort

- 4) โดยตัวระบบป้องกันผู้บุกรุกทางเครือข่ายสามารถป้องกันและตรวจสอบได้ว่ามีใครกำลังพยายามจะบุกรุกโดยใช้ช่องโหว่อะไรเวลาอะไร และเป็นโปรโตคอลอะไรและสามารถดู ip ของผู้บุกรุกได้ด้วย

ID	Signature	Priority	Timestamp	Ip_source	Ip_destination	Type
1-(1-8917)	ICMP Destination Unreachable Port Unreachable	3	2007-01-29 18:43:33	161.246.5.32:	161.246.5.20:	icmp
2-(1-8916)	(spo_bo) Back Orifice Traffic detected		2007-01-29 18:43:33	161.246.5.20:4779	161.246.5.32:9000	udp
3-(1-8915)	ICMP Destination Unreachable Port Unreachable	3	2007-01-29 18:38:13	161.246.5.32:	161.246.5.20:	icmp
4-(1-8914)	(spo_bo) Back Orifice Traffic detected		2007-01-29 18:38:13	161.246.5.20:4736	161.246.5.32:53	udp
5-(1-8913)	ICMP Destination Unreachable Port Unreachable	3	2007-01-29 18:34:45	161.246.5.32:	161.246.5.20:	icmp
6-(1-8912)	(spo_bo) Back Orifice Traffic detected		2007-01-29 18:34:45	161.246.5.20:4706	161.246.5.32:9000	udp
7-(1-8911)	ICMP Destination Unreachable Port Unreachable	3	2007-01-29 18:34:03	161.246.5.32:	161.246.5.20:	icmp
8-(1-8910)	(spo_bo) Back Orifice Traffic detected		2007-01-29 18:34:03	161.246.5.20:4696	161.246.5.32:9000	udp

รูปที่4.4 ระบบขึ้นเตือนและสามารถป้องกันได้

4.3 การทดสอบที่ 2 ทดสอบระบบตรวจจับผู้บุกรุก

1. ทดลองทำการบุกรุกโดยใช้ช่องโหว่ทางซอฟต์แวร์
2. ตรวจสอบว่าระบบสามารถป้องกันได้
3. ทดลองการเปลี่ยนแปลง file แบบต่างๆเพื่อดูว่าระบบสามารถตรวจสอบได้
4. ทดลองตรวจสอบความถูกต้องของไฟล์ว่าระบบสามารถตรวจสอบได้

4.3.1 ผลการทดสอบ

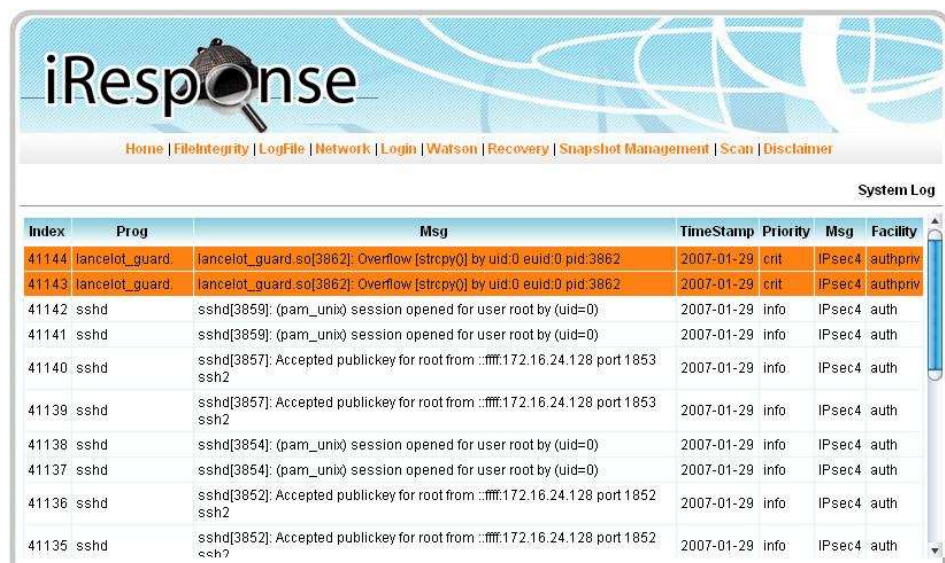
จากการทดสอบพบว่า

1. ถ้าผู้บุกรุกสามารถผ่านระบบป้องกันผู้บุกรุกทางเครือข่ายมาได้และพยายามที่จะยกรับสิทธิ์ของตนเองโดยใช้ช่องโหว่ทางซอฟต์แวร์โดยวิธีการทำฟลอร์โอเวอร์โฟลว์

```
IPsec4:/tmp/watson# ./t1_
```

รูปที่4.5 พยายามทำการยกระดับสิทธิ์ของตนเองโดยใช้ exploit code

2. ตรวจสอบดูว่าระบบสามารถป้องกันได้และรู้ว่าผู้บุกรุกกำลังทำอะไรโดยจะรู้ว่าผู้บุกรุกใช้อะไรในการบุกรุกระบบเรา



The screenshot shows the iResponse web interface with a 'System Log' section. The log contains several entries related to an overflow attack on the lancelot_guard service and subsequent SSH sessions.

Index	Prog	Msg	TimeStamp	Priority	Msg	Facility
41144	lancelot_guard	lancelot_guard.so[3862]: Overflow [strcpy0] by uid:0 euid:0 pid:3862	2007-01-29	crit	IPsec4	authpriv
41143	lancelot_guard	lancelot_guard.so[3862]: Overflow [strcpy0] by uid:0 euid:0 pid:3862	2007-01-29	crit	IPsec4	authpriv
41142	sshd	sshd[3859]: (pam_unix) session opened for user root by (uid=0)	2007-01-29	info	IPsec4	auth
41141	sshd	sshd[3859]: (pam_unix) session opened for user root by (uid=0)	2007-01-29	info	IPsec4	auth
41140	sshd	sshd[3857]: Accepted publickey for root from ::ffff:172.16.24.128 port 1853 ssh2	2007-01-29	info	IPsec4	auth
41139	sshd	sshd[3857]: Accepted publickey for root from ::ffff:172.16.24.128 port 1853 ssh2	2007-01-29	info	IPsec4	auth
41138	sshd	sshd[3854]: (pam_unix) session opened for user root by (uid=0)	2007-01-29	info	IPsec4	auth
41137	sshd	sshd[3854]: (pam_unix) session opened for user root by (uid=0)	2007-01-29	info	IPsec4	auth
41136	sshd	sshd[3852]: Accepted publickey for root from ::ffff:172.16.24.128 port 1852 ssh2	2007-01-29	info	IPsec4	auth
41135	sshd	sshd[3852]: Accepted publickey for root from ::ffff:172.16.24.128 port 1852 ssh2	2007-01-29	info	IPsec4	auth

รูปที่4.6 ระบบสามารถตรวจสอบการบุกรุกได้

3. ผู้บุกรุกพยายามเปลี่ยนแปลง file

3.1 ทดลองโดยการเปิด editor เพื่อ write file

```
IPsec4:/etc/snort# vim test
```

3.2 ใน file มีข้อความอยู่

```
1 change for test kernel module
```

3.3 ทดลองโดยเพิ่มข้อความลงไป

```
1 change for test kernel module
2 hello world test test test test
```

4. ระบบสามารถตรวจจับได้ว่าผู้บุกรุกทำอะไรกับไฟล์ไหนทำอะไรบ้าง

Index	Prog	Msg	TimeStamp	Priority	Msg	Facility
40836	kernel	kernel: /etc/snort/test.swp was chmod to 644 by 0.	2007-01-29	warning	IPsec4	kern
40835	kernel	kernel: /etc/snort/test.swp was chmod to 644 by 0.	2007-01-29	warning	IPsec4	kern
40834	kernel	kernel: /etc/snort/test.swp was removed by 0.	2007-01-29	warning	IPsec4	kern
40833	kernel	kernel: /etc/snort/test.swp was removed by 0.	2007-01-29	warning	IPsec4	kern
40832	kernel	kernel: /etc/snort/test.swpx was removed by 0.	2007-01-29	warning	IPsec4	kern
40831	kernel	kernel: /etc/snort/test.swpx was removed by 0.	2007-01-29	warning	IPsec4	kern

รูปที่ 4.7 kernel สามารถตรวจจับได้เมื่อมีการเขียนทับ file

5. ใช้ ส่วนของความถูกต้องของไฟล์เพื่อตรวจว่า file ที่ทำการดักจับได้นั้นถูกเปลี่ยนแปลงหรือเปล่าหรือเปล่าเวลาไหนเมื่อไร

File Integrity :				Page : [1]
ID	File / Directory Name	Error Detail	Time	
1	/etc/snort/test	This file has been modified	2007-01-29 14:24:15	

รูปที่ 4.8 ใช้โปรแกรมสำหรับเช็ก file integrity

4.4 การทดสอบที่ 3 ทดสอบการกู้คืนระบบ

1. ทำการ snapshot file path ที่สำคัญ
2. ทำการกู้คืนระบบของไฟล์ที่โดนเปลี่ยนแปลง

4.4.1 ผลการทดสอบ

จากการทดสอบพบว่า

1. ทำการเลือก path ที่จะทำการ snapshot และ config เวลาการเก็บให้เหมาะสม

iResponse

Home | FileIntegrity | LogFile | Network | Login | Watson | Recovery | Snapshot Management | Scan | Disclaimer

Snapshot Management :

Path List :

No.	Path name	Status	Action
1	/etc	Stoped	 
2	/home	Working	

Path:

Snapshot Configure : /etc

Keep snapshot (Main Step) :

Round Reuse

Years Months Days

Keep snapshot every

Years Months Days

Keep snapshot (Sub Step) :

Round Reuse

Days Hours

Keep snapshot every

Hours Minutes

Incident Response Group @ ISAG . All Right Reserved

รูปที่ 4.9 การทำ snapshot

2. ตรวจสอบดูว่าระบบได้ทำการbackup หรือเปล่า

```

2008701121832.tar.bz2 2008701121932.tar.bz2 2008701122032.tar.bz2
2008701121834.tar.bz2 2008701121934.tar.bz2 2008701122034.tar.bz2
2008701121836.tar.bz2 2008701121936.tar.bz2 2008701122036.tar.bz2
2008701121838.tar.bz2 2008701121938.tar.bz2 2008701122038.tar.bz2
2008701121840.tar.bz2 2008701121940.tar.bz2 2008701122040.tar.bz2
2008701121842.tar.bz2 2008701121942.tar.bz2 2008701122042.tar.bz2
2008701121844.tar.bz2 2008701121944.tar.bz2 2008701122044.tar.bz2
2008701121846.tar.bz2 2008701121946.tar.bz2 2008701122046.tar.bz2
2008701121848.tar.bz2 2008701121948.tar.bz2 2008701122048.tar.bz2
2008701121850.tar.bz2 2008701121950.tar.bz2 2008701122050.tar.bz2
2008701121852.tar.bz2 2008701121952.tar.bz2 2008701122052.tar.bz2
2008701121854.tar.bz2 2008701121954.tar.bz2 2008701122054.tar.bz2

```

รูปที่ 4.10 file ที่ได้ทำการ snapshot

3. ทำการกู้คืนระบบ



iResponse

Home | FileIntegrity | LogFile | Network | Login | Watson | Recovery | Snapshot Management | Scan | Disclaimer

Recovery :

File	Time
/etc/snort/test	200701122110

File

Select Time Year Month Day Hour Min

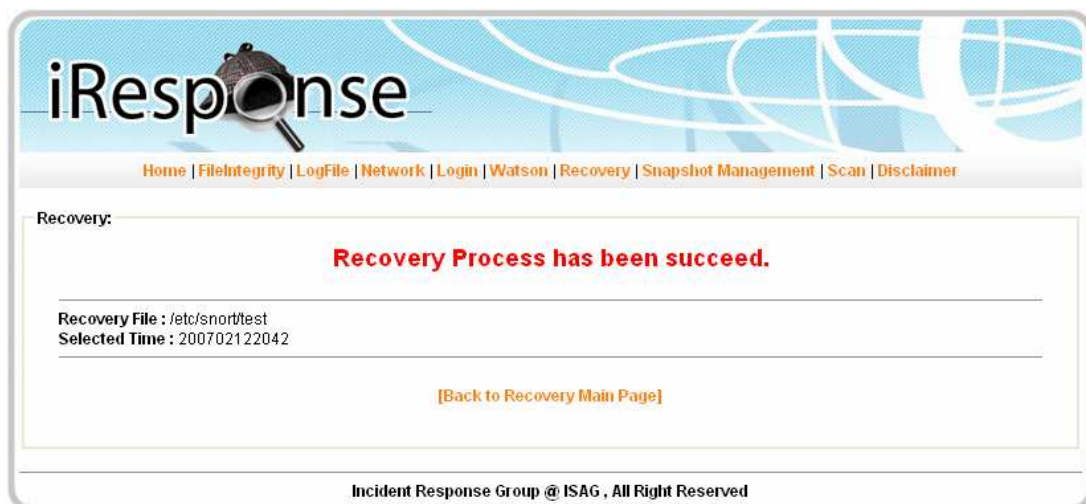
Add Clear

Restore

Incident Response Group @ ISAG , All Right Reserved

รูปที่ 4.11 ทำการเลือก file ที่ทำการ restore

4. ตรวจสอบว่าไฟล์ได้ทำการกู้คืนระบบได้อย่างถูกต้อง



iResponse

Home | FileIntegrity | LogFile | Network | Login | Watson | Recovery | Snapshot Management | Scan | Disclaimer

Recovery:

Recovery Process has been succeed.

Recovery File : /etc/snort/test

Selected Time : 200702122042

[\[Back to Recovery Main Page\]](#)

Incident Response Group @ ISAG , All Right Reserved

รูปที่ 4.12 ทำการ restore เสร็จสมบูรณ์